Runtime risk control repositioning + 90-day roadmap

Memo 18

Bloomsbury Tech – Agentic Payments Hackathon Build

April 25, 2026

Date: 2026-04-25 (late evening, post-pitch-prep refactor)

This memo formalises the venture-development repositioning we picked up from a long strategy review and captures what changed in the codebase as a result. It supersedes the framing in memos 01 and 02 wherever they conflict.

1 TL;DR

We are not "fraud detection for AI". We are:

> **A runtime risk and control layer for autonomous payment agents.** *We monitor, score, and govern financial actions taken by AI agents before money moves.*

This frees us from needing labelled fraud and lets us cover compromise, collusion, prompt-injection, policy breach, and audit — the categories where existing card-and-merchant fraud systems have no signal.

2 What changed in the product

1. Score vector, not single score

`src/models/score.py` returns six sub-scores per wallet plus an overall risk number. The eight underlying behavioural factor signals still exist (they drive the explanations) but the buyer-facing surface is the vector:

Sub-score	What it asks
`agent_likeness_score`	Is this actor machine-shaped? (descriptive — not accusatory)
`drift_score`	Has its behaviour changed inside the window?
`coordination_score`	Does it move in sync with other actors?
`policy_violation_score`	Is this action outside delegated authority?
`counterparty_risk_score`	Is the recipient suspicious?
`prompt_injection_score`	Did external content manipulate the action?

Weights (sum = 1.0) bias toward the dimensions a runtime control buyer cares about: `policy_violation` and `drift` weighted at 25%, agent-likeness at 10% (legitimate automation looks agent-like by design and we don't want to penalise it).

The legacy `composite_score` column is kept as an alias for `overall_action_risk` so the Streamlit dashboard, the JSON exporter, and existing tests keep working without back-compat shims.

2. Three-decision framing — Allow / Review / Block

Both UIs (Streamlit `Live Risk` tab and the Vercel `Live Action Risk` component) now stamp every action with a decision instead of a "fraud yes/no":

- **Allow** — overall risk low, no critical sub-score, no alert.
- **Review** — alert fires, top sub-score 75–89 OR tier high.
- **Block** — top sub-score \$\geq\$ 90 OR tier critical.

This matches the runtime-control product shape: the buyer configures the thresholds per agent.

3. Alerts on any sub-score crossing 75/100

`src/live/tracker.py` previously alerted only when the wallet entered the top 8% of `composite_score`. With six dimensions, that's the wrong gate — "this wallet is at 95 on policy violation" is a louder signal than "overall composite at 44, top of bell curve". The new gate fires when either of two conditions is true (and the cooldown allows):

1. The wallet's `overall_action_risk` enters the live population's top 8%, OR
2. Any of the six sub-scores \$\geq\$ `ALERT_SUBSCORE_FLOOR` (75/100).

`MIN_WALLET_TX` was lowered from 8 to 3 because the public x402 sample's median wallet has 1–3 transactions and the old threshold suppressed all real-data alerts. Synthetic scenarios have 50+ tx per wallet so the floor is only protective against single-tx noise.

4. Four scenario presets

`scripts/export_to_web.py` now emits four pre-rolled streams under `web/public/data/scenarios/<key>/`:

- **`base_x402`** — recorded public x402 EIP-3009 settlements; the honest

demo. 29 alerts in a 360-tick replay.

- **`compromised_drift`** — synthetic, 20 compromised agents drift after

t=8h. Drift-led alerts, ~58 in 360 ticks.

- **`collusion_ring`** — synthetic, four rings of 6–9 wallets each fire

coordinated bursts. Coordination-led alert.

- **`prompt_injected_invoice`** — synthetic, the new policy from

`src/ingest/synthetic.py:gen_prompt_injected_invoice`. Agent reads a tampered invoice mid-window, diverts payments to an attacker wallet. This is the agentic-specific failure mode that justifies the runtime- control category (no card fraud system has a signal for this).

Each scenario has its own `events.json`, `scores.json`, `embedding.json`. The web LiveTracker / Leaderboard / BehaviourMap components have a scenario selector at the top.

5. New synthetic policy: `prompt_injected_invoice`

`gen_prompt_injected_invoice(world, addr, injection_t=6h)` produces an agent that:

- Phase 1 (t < injection_t): well-behaved x402 payment-bot to a known

vendor. Looks identical to `agent_payment_bot`.

- Phase 2: the injected invoice rewrites the payment address. Agent

diverts payments to an attacker wallet from `world.malicious_pool`. Each diverted tx carries `prompt_injection_flag=True` — this is the runtime hook a real product would surface from the agent's tool trace; the synthetic generator just stamps it directly so the scoring path can detect it.

The flag is aggregated by `compute_features()` into `prompt_injection_share`, which `_subscores()` rolls into `prompt_injection_score`. In real-data ingest paths the column is absent and the score defaults to 0 — honest about what the system can and cannot see today.

3 What we did *not* build (and why)

We resisted the urge to ship a half-baked version of the full venture roadmap before the Saturday pitch. Specifically, the following live in memo 18's *roadmap* section, not the codebase:

- Canonical entity graph (Agent / User / Tool / Invoice / etc.). The

current product is wallet-centric; entity-centric is post-pitch.

- Hard policy engine. Today the policy_violation_score is a behavioural

proxy (large_value_share + new_counterparty_late_share). The next milestone is configurable rules with simulation mode.

- Pre-transaction `risk.checkAction()` API. Today we replay; the runtime

hook is the next milestone.

- Case queue / review workflow. Mocked in the dashboard, not yet a real

workflow.

Shipping fakes of these would have undermined the methodology pitch. Naming them as the next 90 days is stronger as an investor story than showing a stub.

4 Disclaimer (now in the web Footer)

> Demo uses synthetic ground-truth labels and recently-decoded public Base x402 settlements. Scores reflect behavioural anomaly and policy-breach likelihood, not legal determinations.

The web Footer now has a "What we score / What we explicitly don't" two-column block above the memo grid. This is intentional honesty: a buyer or judge who reads it sees that we know exactly what we have and don't, which is more credible than an over-claim.

5 90-day roadmap (deck slide)

Days	Milestone
1–10	Pre-pitch repositioning (this memo, score vector, scenarios) — DONE
11–30	Canonical event schema (`payment_event`, `agent_action_event`, `tool_call_event`, `authorization_po`
31–60	`risk.checkAction()` pre-transaction API + LangChain / OpenAI Agents / MCP integration
61–90	Pilot package: data import templates, risk report generator, policy simulation, pilot pricing

6 Wedge vs incumbents (one-liner per)

Incumbent	Their lane	Our wedge
Stripe Radar	Card / merchant fraud	We govern the agent **before** Stripe sees the payment
Visa / MA	Network-level authorization	We score agent behaviour across rails and runtimes
Sardine / Sift	Human + device fingerprints	We fingerprint **agents**: tools, delegation, drift
Chainalysis	Wallet illicit-fund tracing	We score behavioural risk + policy breach + injection

7 Code pointers

Area	Path
Six sub-scores	`src/models/score.py`
Prompt-injected scenario	`src/ingest/synthetic.py:gen_prompt_injected_invo`
Live tracker alert logic	`src/live/tracker.py`
Scenario JSON export	`scripts/export_to_web.py`
Web LiveTracker (sub-score bars + decision badges)	`web/components/LiveTracker.tsx`
Web Leaderboard (top sub-score column)	`web/components/Leaderboard.tsx`
Web Hero (positioning)	`web/components/Hero.tsx`
Web Footer (threat model + disclaimer)	`web/components/Footer.tsx`

8 Next memo

`19_pre_seed_deck_outline.md` will translate this into the 12-slide investor deck. Out of scope tonight.